



32-MAVZU · IV BOB. PYTHON, POSTGRESQL VA DJANGO

Python dasturlash tilini PostgreSQL ma'lumotlar bazasiga bog'lash

Virtual muhit, psycopg kutubxonasi, ulanish, kursor, SQL so'rovlarni Python'dan bajarish, parametrli so'rovlar va SQL injection xavfi, commit va rollback, maxfiy sozlamalar; Python + PostgreSQL CRUD konsol dasturi.

8-sinf · Web Full-stack dasturlash

Bugun nimani o'rganamiz?

- Python dasturi bazaga qanday "**gaplashadi**"
- **Virtual muhit** va **psycopg** kutubxonasi
- Ulanish, so'rov yuborish, natija olish
- Eng xavfli zaiflik — **SQL injection** va himoya
- Python + PostgreSQL CRUD konsol dasturi (20-loyiha)

Python va baza qanday bog'lanadi?

- III bobda SQL'ni pgAdmin'da **qo'lda** yozdik
- Haqiqiy ilovada SQL'ni **dastur** yuboradi: forma → Python → **INSERT**

Matn

 Python dasturi (sizning kodingiz) →  psycpg ("tarjimon") — SQL (port 5432) →  PostgreSQL natija qatorlari



Telefon qo'ng'irog'i: ulanish — raqam terish; cursor — savol berib javob olish; commit — "kelishdik, yozib qo'yning"; close — go'shakni qo'yish.

Virtual muhit (venv)

Terminal

```
mkdir maktab_app
cd maktab_app
python -m venv venv          # virtual muhit
venv\Scripts\activate       # Windows
source venv/bin/activate    # macOS / Linux
pip install "psycopyg[binary]" # PostgreSQL kutubxonasi
pip freeze > requirements.txt # paketlar ro'yxati
```

- Har loyiha o'z paketlarini alohida "**quti**"da saqlaydi
- Boshqa kompyuterda: `pip install -r requirements.txt`



`venv` papkasini GitHub'ga yuklamang (`.gitignore`)

Birinchi ulanish

Python

```
import psycopgp

with psycopgp.connect("dbname=maktab user=postgres password=PAROL host=localhost") as conn:
    with conn.cursor() as cur:
        cur.execute("SELECT id, ism, familiya FROM oquvchilar ORDER BY familiya")
        for qator in cur.fetchall():
            print(qator)

# with tugaganda: xato yo'q – commit, xato – rollback, ulanish yopiladi
```

Natija

```
(6, 'Dilnoza', 'Aminova')
(4, 'Madina', 'Ergasheva')
(2, 'Zarina', 'Karimova')
```

Kursor metodlari

Metod	Vazifasi
<code>cur.execute(sql, params)</code>	So'rovni bajarish
<code>cur.fetchone()</code>	Keyingi bitta qator (yoki <code>None</code>)
<code>cur.fetchall()</code>	Barcha qatorlar ro'yxati
<code>cur.fetchmany(5)</code>	Keyingi 5 ta qator
<code>cur.rowcount</code>	O'zgargan qatorlar soni
<code>conn.commit()</code> / <code>conn.rollback()</code>	Saqlash / bekor qilish



`INSERT/UPDATE/DELETE` dan keyin commit bo'lmasa — o'zgarish **saqlanmaydi**

⚠ SQL injection — eng xavfli xato

Python

```
# ❌ HECH QACHON BUNDAY QILMANG  
ism = input("Ism: ")  
cur.execute(f"SELECT * FROM oquvchilar WHERE ism = '{ism}'")
```

- Buzg'unchi yozadi: `' OR '1'='1'`

SQL

```
SELECT * FROM oquvchilar WHERE ism = '' OR '1'='1' -- doim rost → HAMMA ma'lumot!
```

- Yoki: `'; DROP TABLE oquvchilar; --` → jadval o'chadi!



Buyruq qog'ozi: "Ombordan ____ ni olib kel". Ayyor mijoz yozadi: "olma. Keyin seyfdagi pullarni ham". Parametrli so'rov bo'sh joyni faqat **mahsulot nomi** deb tushunadi.



Parametrli so'rov

Python

```
ism = input("Ism: ")
cur.execute("SELECT * FROM oquvchilar WHERE ism = %s", (ism,))  # (ism,) - tuple!

cur.execute(
    "INSERT INTO oquvchilar (ism, familiya, sinf_id) VALUES (%s, %s, %s)",
    ("Jasur", "Rahimov", 2),
)
```

SQL'ga kiradigan har qanday qiymat — faqat %s orqali

- `%s` — barcha turlar uchun (son uchun ham), **qo'shtirnoqsiz**
- f-string, `+`, `.format()` bilan SQL **yasamang!**

CRUD'ni Python'dan bajarish

Python

```
with psycopg.connect(DSN) as conn:
    with conn.cursor() as cur:
        cur.execute(
            "INSERT INTO oquvchilar (ism, familiya, sinf_id) VALUES (%s, %s, %s) RETURNING id",
            ("Laylo", "Usmonova", 1))
        yangi_id = cur.fetchone()[0]                                # CREATE

        cur.execute("SELECT ism, familiya FROM oquvchilar WHERE id = %s", (yangi_id,))
        print(cur.fetchone())                                      # READ

        cur.execute("UPDATE oquvchilar SET sinf_id = %s WHERE id = %s", (2, yangi_id))
        print("O'zgardi:", cur.rowcount)                          # UPDATE

        cur.execute("DELETE FROM oquvchilar WHERE id = %s", (yangi_id,))    # DELETE
```

Natija dict ko'rinishida va .env

Python

```
from psycopg.rows import dict_row
with psycopg.connect(DSN, row_factory=dict_row) as conn:
    for r in conn.execute("SELECT id, ism FROM oquvchilar LIMIT 2").fetchall():
        print(r["ism"])           # nom bilan — o'qilishi oson
```

.env

```
DB_NAME=maktab
DB_USER=postgres
DB_PASSWORD=SIZNING_PAROLINGIZ
DB_HOST=localhost
```

db.py

```
import os, psycopg
from psycopg.rows import dict_row
from dotenv import load_dotenv
load_dotenv()

def ulanish():
    return psycopg.connect(
        dbname=os.getenv("DB_NAME"),
        user=os.getenv("DB_USER"),
        password=os.getenv("DB_PASSWORD"),
        host=os.getenv("DB_HOST"),
        row_factory=dict_row,
    )
```



Parolni kodda yozib GitHub'ga yuklasangiz — butun dunyo ko'radi! `.env`

→ `.gitignore`

Amaliyot: CRUD dasturi (20-loyiha)

Python

```
from db import ulanish

def royxat():
    with ulanish() as conn:
        rows = conn.execute("""
            SELECT o.id, o.ism, o.familiya, s.nomi AS sinf,
                   ROUND(AVG(b.baho), 2) AS ortacha
            FROM oquvchilar o
            LEFT JOIN sinflar s ON s.id = o.sinf_id
            LEFT JOIN baholar b ON b.oquvchi_id = o.id
            GROUP BY o.id, s.nomi ORDER BY o.familiya
        """).fetchall()
    for r in rows:
        print(f"{r['id']:<4}{r['ism']:<12}{r['familiya']:<14}{r['sinf'] or '-':<6}{r['ortacha'] or '-'}")

def qidirish(soz):
    with ulanish() as conn:
        return conn.execute(
            "SELECT * FROM oquvchilar WHERE ism ILIKE %s OR familiya ILIKE %s",
            (f"%{soz}%", f"%{soz}%")).fetchall()
```

Amaliyot: topshiriqlar

- 1 Dasturni ishga tushiring — pgAdmin'da o'zgarishlarni kuzating
- 2 "Qidirish"ga `' OR '1'='1` yozing — **teshik yo'qligiga** ishonch hosil qiling
- 3 **"Sinf statistikasi"** menyu bandi (GROUP BY)
- 4 **"Tahrirlash"** menyu bandi (UPDATE)

Ko'p uchraydigan xatolar

- ❌ `No module named 'psycopg'` — venv faol emas yoki paket o'rnatilmagan
- ❌ `connection refused` — server ishlamayapti yoki host/port xato
- ❌ `(ism)` — bu tuple emas! To'g'risi `(ism,)`
- ❌ `'%s'` — qo'shtirnoq ichida; to'g'risi `%s`
- ❌ `commit` qilinmagan — ma'lumot "yo'qoldi"

Savol

Python'dan PostgreSQL bilan ishlash uchun kutubxona?

A requests

B psycopg

C pygame

D flask

Javobni tanlang — to'g'ri variant yashil bo'ladi

Savol

INSERT dan keyin o'zgarishni saqlash uchun nima chaqiriladi?

A `cur.save()`

B `conn.close()`

C `cur.fetchone()`

D `conn.commit()`

Javobni tanlang — to'g'ri variant yashil bo'ladi

Savol

SQL injection'dan himoyalangan to'g'ri kod?

A `cur.execute("... WHERE ism = %s",
(ism,))`

B `cur.execute(f"... WHERE ism =
'{ism}'")`

C `cur.execute("... WHERE ism = '" + ism
+ "'")`

D `cur.execute("... = {}".format(ism))`

Javobni tanlang — to'g'ri variant yashil bo'ladi

Savol

Parol kabi maxfiy sozlamalarni qayerda saqlash to'g'ri?

A Kod ichida, izoh bilan

B `.env` faylida (GitHub'ga yuklanmaydi)

C README faylida

D Baza nomida

Javobni tanlang — to'g'ri variant yashil bo'ladi



Uyga vazifa

- 1 **Do'kon dasturi:** mahsulotlar ro'yxati, qo'shish, narxni o'zgartirish, tugaganlar
- 2 **"Buyurtma berish":** `buyurtmalar` + `buyurtma_tarkibi` ga yozish va ombordagi sonni kamaytirish — **bitta tranzaksiyada**

✓ Yodda tuting

- `python -m venv venv` → faollashtirish → `pip install "psycopg[binary]"`
- `with psycopg.connect(...) as conn:` → `execute(sql, params)` → `fetchone/fetchall`
- Faqat **parametrli** so'rovlar: `%s` + tuple
- Maxfiy sozlamalar — `.env` da, `.gitignore` ga qo'shilgan



Savollar bormi?

Keyingi mavzu: **33. Django frameworkiga kirish. Arxitektura, loyiha va ilova (App) yaratish**

Batafsil matn, misollar va testlar: **[32-python-postgresql.html](#)** darsida